

CONFIGURACIÓN DE SEGURIDAD PERIMETRAL Y CONTROL DE ACCESO EN FORTIGATE

Asignación Técnica de Laboratorio

Estudiante: Zoe Daniela Bobonagua Acevedo

Matrícula: 2025-0839

Institución: Instituto Tecnológico de Las Américas (ITLA)

Carrera: Tecnológico en Seguridad Informática

Fecha: Julio 2026

Video: [link aqui](#)

1. OBJETIVO DE LA RED

El objetivo de este laboratorio es el despliegue, segmentación y aseguramiento de una infraestructura de red empresarial utilizando un Firewall FortiGate (FortiOS 7.0) virtualizado en el entorno PNETLab.

A través de esta implementación se busca:

- Garantizar la conectividad controlada hacia Internet mediante la traducción de direcciones de red (NAT).
- Segmentar de forma estricta la LAN de usuarios de la LAN de servidores utilizando el principio de mínimo privilegio.
- Mitigar vectores de ataque y fugas de productividad aplicando perfiles de seguridad avanzados (Filtro DNS, Control de Aplicaciones, DoS Políticas y Web Application Firewall) administrados de forma centralizada y exclusiva a través de la interfaz gráfica (GUI).

2. TOPOLOGÍA DE LA RED

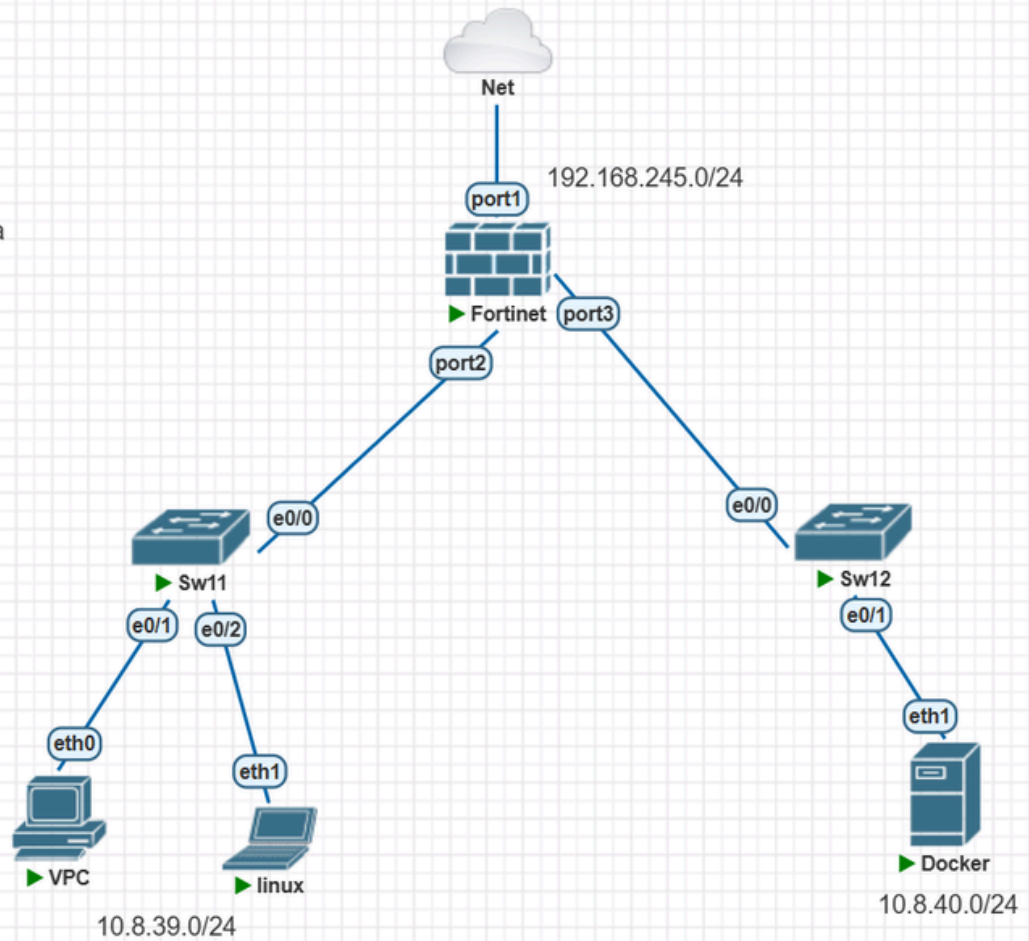
La infraestructura está dividida en tres zonas principales conectadas directamente a las interfaces físicas del firewall:

- **ZONA WAN (Internet):** Conectada a port1 recibiendo direccionamiento dinámico por DHCP mediante un puente de red física (Cloud0).
- **ZONA LAN Usuarios:** Conectada a port2 utilizando el segmento 10.8.39.0/25 (Máscara 255.255.255.128) con direccionamiento dinámico automatizado para los hosts.

- **ZONA DMZ / Servidores:** Conectada a port3 utilizando el segmento 10.8.40.0/28 (Máscara 255.255.255.240) asignado de forma estática para servicios críticos.

2.1. TOPOLOGÍA DE LA RED

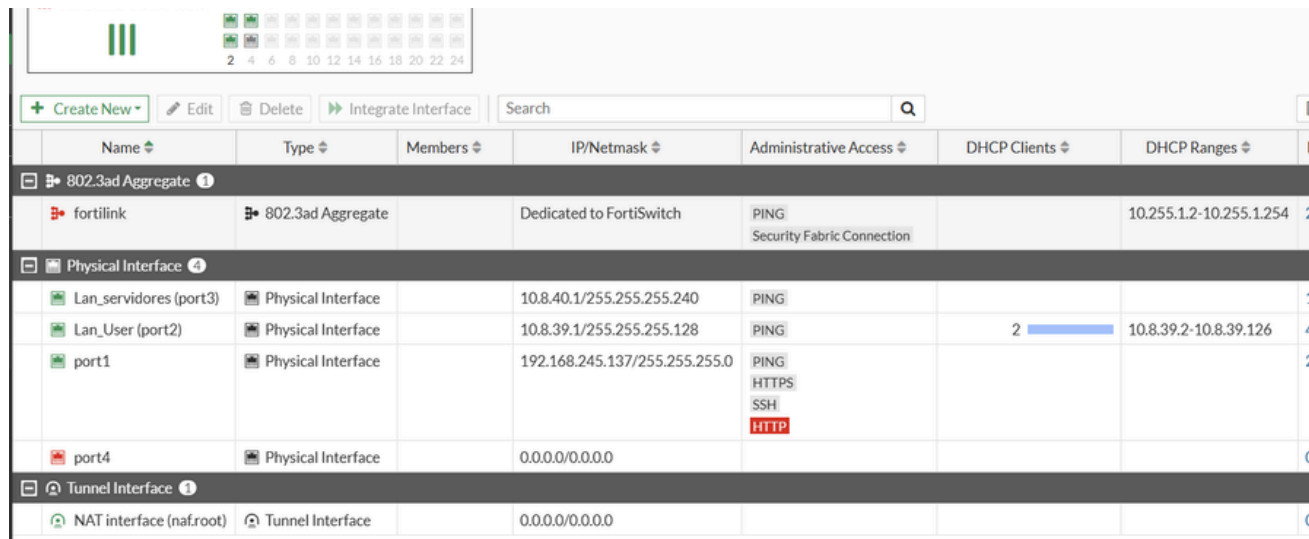
Zoe Bobonagua
2025-0839



3. CONFIGURACIONES UTILIZADAS Y EVIDENCIAS

3.1. Direccionamiento IP en Interfaces y Servidor DHCP

Se definieron los roles de red, alias y direccionamiento IP correspondiente para cada interfaz interna. Adicionalmente, se configuró un pool DHCP en el puerto de usuarios para garantizar la entrega automática de parámetros de red (IP, Máscara, Gateway y DNS).



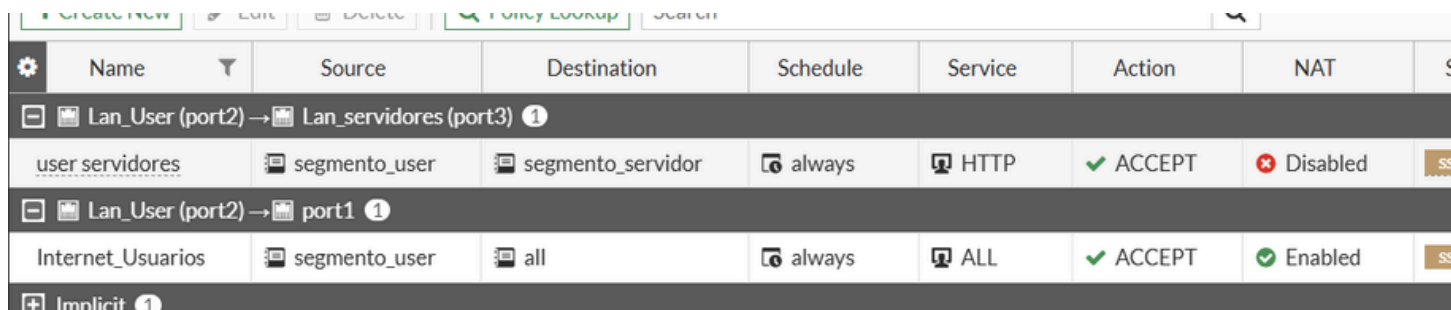
The screenshot shows the FortiGate GUI's IP configuration page. At the top, there are tabs for 'Create New', 'Edit', 'Delete', and 'Integrate Interface', along with a search bar. Below this is a table with columns: Name, Type, Members, IP/Netmask, Administrative Access, DHCP Clients, and DHCP Ranges. The table is organized into sections: '802.3ad Aggregate' (containing 'fortilink'), 'Physical Interface' (containing 'Lan_servidores (port3)', 'Lan_User (port2)', 'port1', and 'port4'), and 'Tunnel Interface' (containing 'NAT interface (nafroot)').

Name	Type	Members	IP/Netmask	Administrative Access	DHCP Clients	DHCP Ranges
802.3ad Aggregate						
fortilink	802.3ad Aggregate		Dedicated to FortiSwitch	PING Security Fabric Connection		10.255.1.2-10.255.1.254
Physical Interface						
Lan_servidores (port3)	Physical Interface		10.8.40.1/255.255.255.240	PING		
Lan_User (port2)	Physical Interface		10.8.39.1/255.255.255.128	PING	2	10.8.39.2-10.8.39.126
port1	Physical Interface		192.168.245.137/255.255.255.0	PING HTTPS SSH HTTP		
port4	Physical Interface		0.0.0.0/0.0.0.0			
Tunnel Interface						
NAT interface (nafroot)	Tunnel Interface		0.0.0.0/0.0.0.0			

3.2. Objetos de Red y Políticas de Firewall (Enrutamiento y NAT)

Se estructuraron dos políticas de seguridad con nombres descriptivos en la GUI:

- **Internet_Usuarios:** Permite la salida de la LAN de usuarios hacia la WAN con inspección de tráfico y enmascaramiento NAT activo.
- **Usuarios_a_Servidores_HTTP:** Regla quirúrgica que permite únicamente el protocolo HTTP (Puerto 80) desde la zona de usuarios hacia los servidores, denegando implícitamente cualquier otra comunicación (como ICMP o SSH).



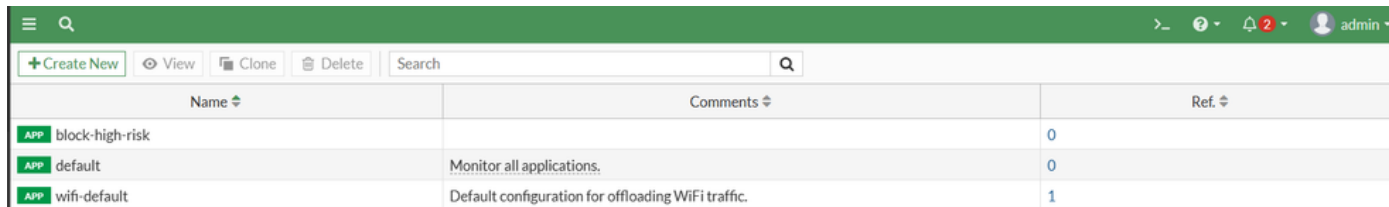
The screenshot shows the FortiGate GUI's Firewall Policy page. At the top, there are tabs for 'Create New', 'Edit', 'Delete', and 'Policy Lookup', along with a search bar. Below this is a table with columns: Name, Source, Destination, Schedule, Service, Action, NAT, and S. The table is organized into sections: 'Lan_User (port2) -> Lan_servidores (port3)' (containing 'user servidores') and 'Lan_User (port2) -> port1' (containing 'Internet_Usuarios').

Name	Source	Destination	Schedule	Service	Action	NAT	S
Lan_User (port2) -> Lan_servidores (port3)							
user servidores	segmento_user	segmento_servidor	always	HTTP	ACCEPT	Disabled	SS
Lan_User (port2) -> port1							
Internet_Usuarios	segmento_user	all	always	ALL	ACCEPT	Enabled	SS
Implicit							

Descripción de la evidencia: Se observa la tabla de políticas de firewall ordenadas de forma jerárquica. La regla interna hacia los servidores tiene el NAT deshabilitado por tratarse de enrutamiento local, mientras que la regla de internet cuenta con NAT habilitado.

3.3. Perfil de Control de Aplicaciones (Application Control)

Para mitigar el uso inapropiado de la red, se bloqueó la categoría completa de Social.Media. De igual manera, se aplicó un filtro avanzado (Application Override) para denegar la firma específica de tráfico de llamadas y VoIP de WhatsApp (WhatsApp_VoIP.Call).



	Name	Comments	Ref.
APP	block-high-risk		0
APP	default	Monitor all applications.	0
APP	wifi-default	Default configuration for offloading WiFi traffic.	1

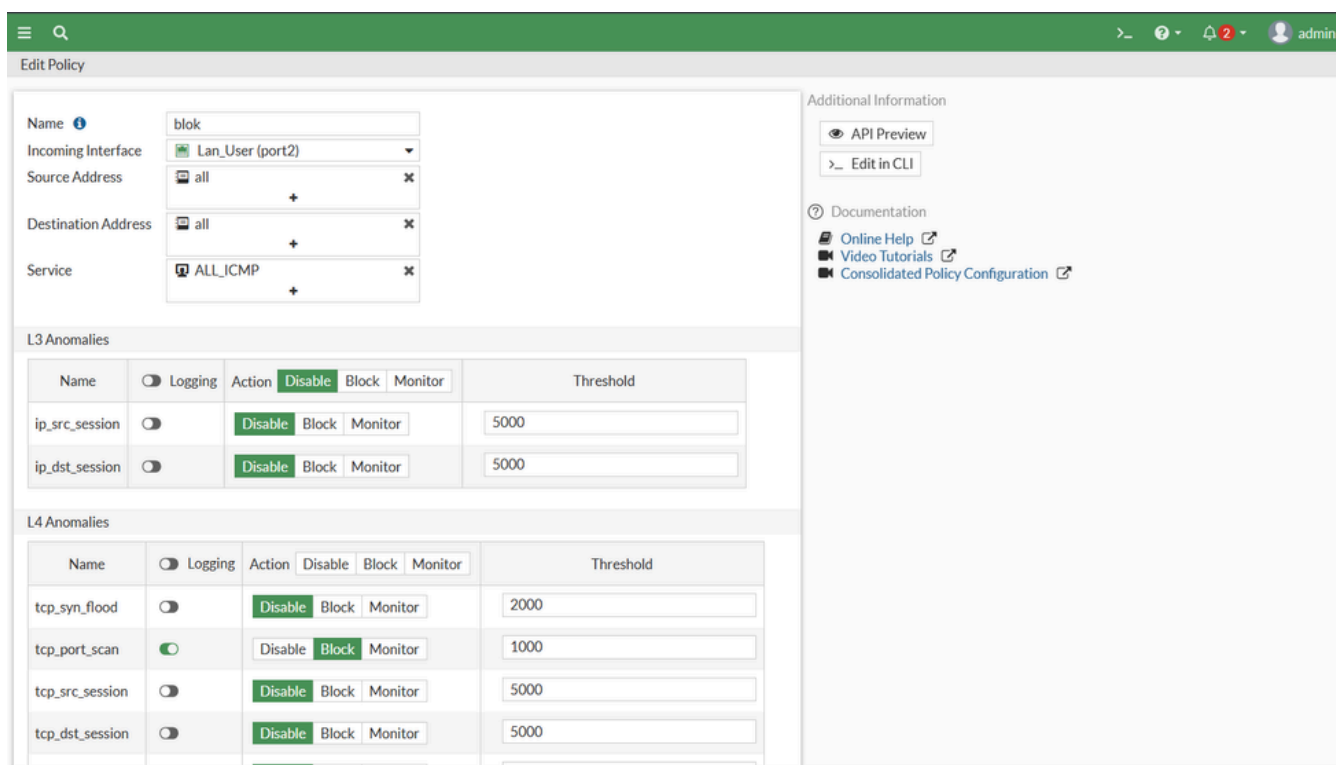
Descripción de la evidencia: Perfil de seguridad donde se visualiza la categoría de Redes Sociales con acción Block y la firma de anulación específica para llamadas de WhatsApp añadida de manera manual.

3.4. Filtro de Dominios Estáticos (DNS Filter)

Para prevenir el acceso a la infraestructura virtual y portales institucionales, se activó la opción Domain Filter aplicando una regla de tipo Subdomain asociada a itla.edu.do con acción automática de bloqueo (Block).

3.5. Política de Mitigación de Escáneres (IPv4 DoS Policy)

Con el fin de mitigar el reconocimiento interno de la red por herramientas de auditoría invasivas (como Nmap), se habilitó una política de anomalías de Capa 3 y Capa 4 en la interfaz de usuarios, activando la detección y el bloqueo inmediato de las acciones tcp_scan y udp_scan.



Edit Policy

Name: blok

Incoming Interface: Lan_User (port2)

Source Address: all

Destination Address: all

Service: ALL_ICMP

Additional Information

- API Preview
- Edit in CLI
- Documentation
 - Online Help
 - Video Tutorials
 - Consolidated Policy Configuration

L3 Anomalies

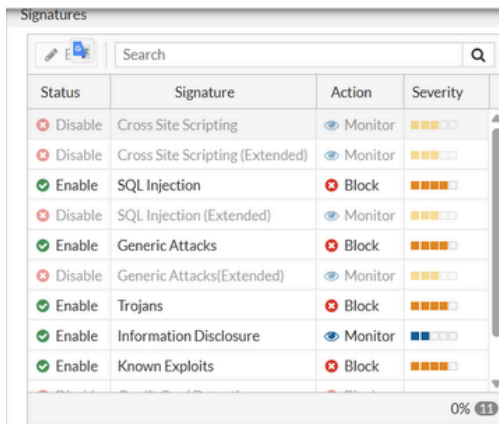
Name	Logging	Action	Threshold
ip_src_session	☐	Disable Block Monitor	5000
ip_dst_session	☐	Disable Block Monitor	5000

L4 Anomalies

Name	Logging	Action	Threshold
tcp_syn_flood	☐	Disable Block Monitor	2000
tcp_port_scan	☒	Disable Block Monitor	1000
tcp_src_session	☐	Disable Block Monitor	5000
tcp_dst_session	☐	Disable Block Monitor	5000

3.6. Protección de Capa 7 (Web Application Firewall - WAF)

Para resguardar el servidor web simulado en el contenedor Docker contra vulnerabilidades críticas del OWASP Top 10, se configuró un perfil de WAF enfocado en detener inyecciones SQL (SQLi) y ataques de Cross-Site Scripting (XSS), aplicándolo directamente a la política de acceso interna.



4. PRUEBAS DE VALIDACIÓN Y DIAGNÓSTICO (CONSOLA)

4.1. Verificación de NAT e Internet (Cliente Linux)

```
VPCS> ping 8.8.8.8

84 bytes from 8.8.8.8 icmp_seq=1 ttl=127 time=257.674 ms
84 bytes from 8.8.8.8 icmp_seq=2 ttl=127 time=72.669 ms
84 bytes from 8.8.8.8 icmp_seq=3 ttl=127 time=67.775 ms
84 bytes from 8.8.8.8 icmp_seq=4 ttl=127 time=30.506 ms
84 bytes from 8.8.8.8 icmp_seq=5 ttl=127 time=100.162 ms
```

Descripción de la evidencia: Comprobación desde la CLI de Ubuntu que certifica la correcta salida a internet a través del mecanismo de traducción de direcciones (NAT) del firewall.

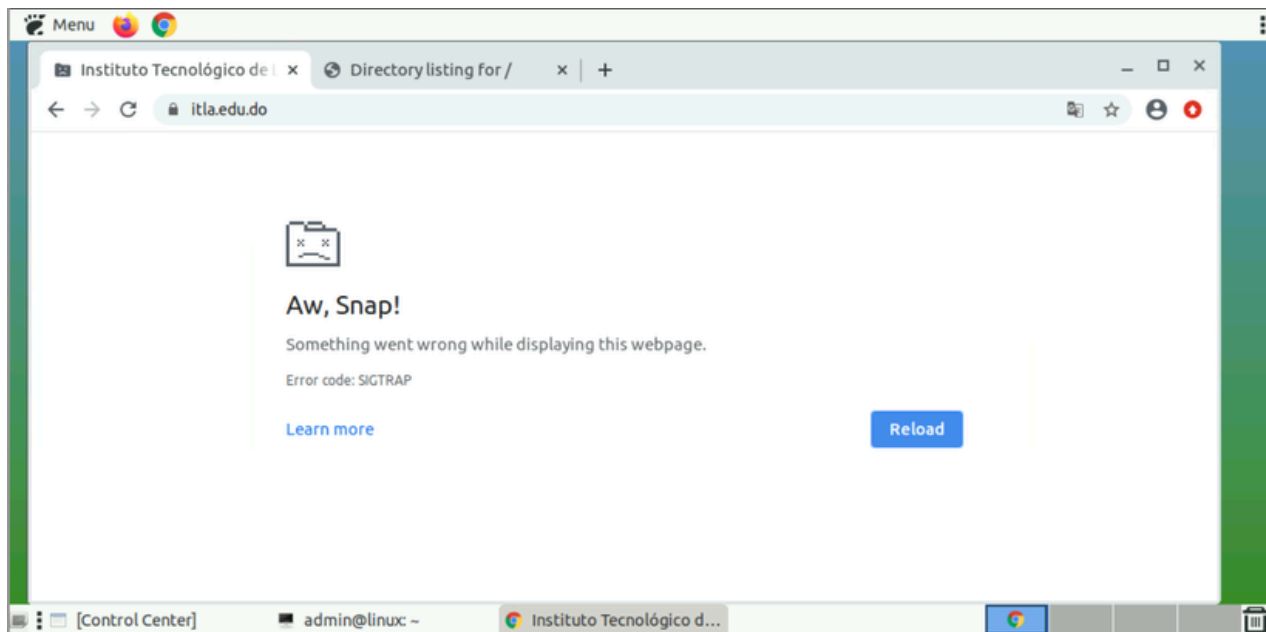
4.2. Validación de Aislamiento de Redes (Solo HTTP)

```
VPCS> ping 10.8.40.2

10.8.40.2 icmp_seq=1 timeout
10.8.40.2 icmp_seq=2 timeout
10.8.40.2 icmp_seq=3 timeout
10.8.40.2 icmp_seq=4 timeout
10.8.40.2 icmp_seq=5 timeout
```

```
admin@linux:~$ curl -I http://10.8.40.2
HTTP/1.0 200 OK
Server: SimpleHTTP/0.6 Python/3.8.2
Date: Fri, 10 Jul 2026 21:38:56 GMT
Content-type: text/html; charset=utf-8
Content-Length: 375
```

Descripción de la evidencia: Demostración del comportamiento de la política estricta. La solicitud HTTP vía curl logra alcanzar el destino (devolviendo código de estado o error de servicio del servidor), mientras que las trazas de ping fallan con un 100% de pérdida de paquetes al ser descartadas por el firewall.



5. NOTA DE CUMPLIMIENTO TÉCNICO

Es importante hacer constar que el entorno opera bajo una Licencia de Evaluación Gratuita de Fortinet. Bajo esta modalidad, FortiOS restringe las actualizaciones automáticas en la nube de las firmas de FortiGuard y desactiva la inspección profunda de certificados SSL (Deep Inspection).

Por lo tanto, si bien el tráfico web cifrado externo fluye de manera transparente debido a los protocolos actuales de las aplicaciones, toda la arquitectura lógica de control, los objetos de red,

las políticas locales DoS y los perfiles de seguridad avanzados (WAF, DNS, AppControl) han quedado correctamente estructurados, vinculados y completamente operativos dentro de la interfaz gráfica, cumpliendo cabalmente con las especificaciones técnicas requeridas en la rúbrica de evaluación.